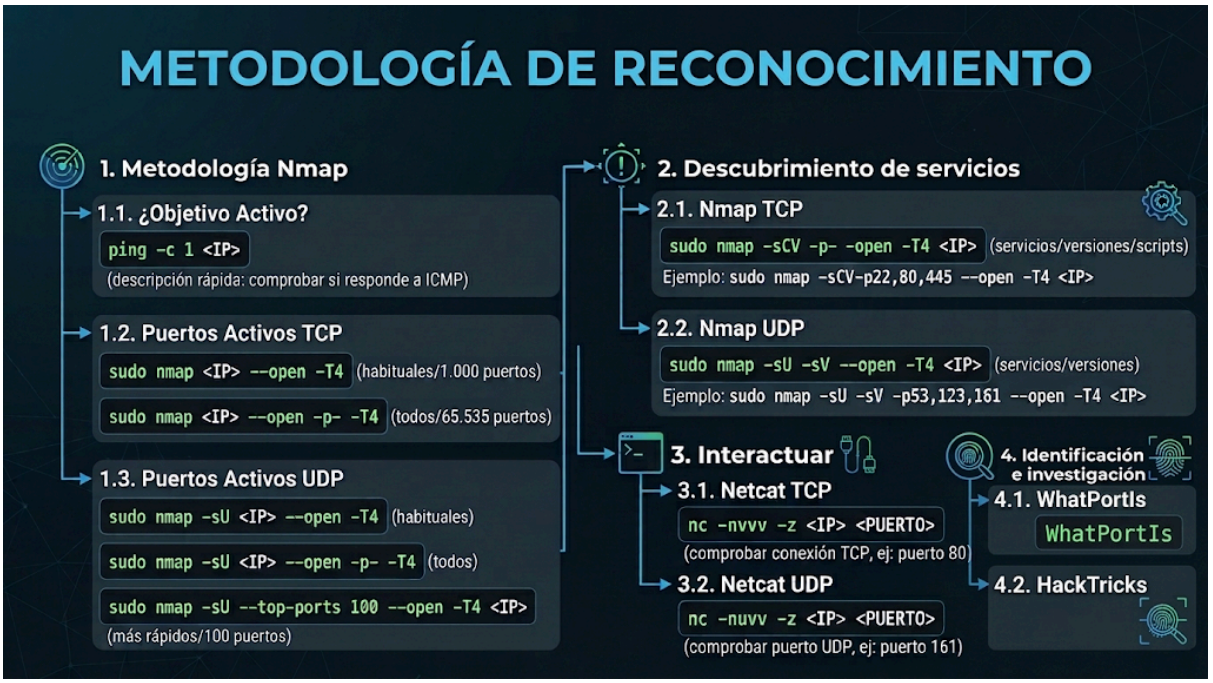


Índice:

1. Metodología Nmap..... 2
1.1. Comprobar si el objetivo está activo..... 2
1.2. Comprobar puertos con servicios activos (TCP)..... 2
1.3. Comprobar puertos con servicios activos (UDP)..... 2
2. Descubrimiento de servicios y versiones..... 4
2.1. Nmap TCP..... 4
2.2. Nmap UDP..... 4
3. Interactuar con el servicio..... 6
3.1. Netcat TCP..... 6
3.2. Netcat UDP..... 6
4. Identificación e investigación de servicios..... 7
4.1. Whatportis..... 7
4.2. HackTricks..... 7

Mohammed Taamart

1. Metodología Nmap

1.1. Comprobar si el objetivo está activo

Comando:

ping -c 1 <IP>

Este comando envía una solicitud ICMP al objetivo para comprobar si responde.

Que no responda al ping no significa que la máquina esté apagada, ya que puede bloquear las solicitudes ICMP o filtrar este tipo de tráfico.

1.2. Comprobar puertos con servicios activos (TCP)

Comando:

sudo nmap <IP> --open -T4

Realiza un escaneo de los puertos TCP más habituales de la máquina objetivo para identificar posibles servicios expuestos, mostrando los puertos que Nmap considera abiertos o potencialmente abiertos y utilizando una temporización rápida para agilizar el proceso.

Por defecto, Nmap escanea los 1.000 puertos TCP más habituales.

Si queremos realizar un escaneo más exhaustivo, revisando todos los puertos TCP, utilizaremos el siguiente comando:

sudo nmap <IP> --open -p- -T4

Este escaneo puede tardar más tiempo, ya que revisa los 65.535 puertos TCP. Sin embargo, permite identificar servicios que podrían pasar desapercibidos si únicamente escaneamos los puertos más comunes.

1.3. Comprobar puertos con servicios activos (UDP)

Comando:

sudo nmap -sU <IP> --open -T4

Realiza un escaneo de los puertos UDP más habituales de la máquina objetivo para identificar posibles servicios expuestos, mostrando los puertos abiertos o potencialmente abiertos y utilizando una temporización rápida para agilizar el proceso.

Los escaneos UDP suelen tardar más que los TCP, ya que muchos servicios no responden a las sondas enviadas por Nmap, lo que dificulta determinar el estado de los puertos.

Si queremos realizar un escaneo de todos los puertos UDP, utilizaremos el siguiente comando:

sudo nmap -sU <IP> --open -p- -T4

Este escaneo puede tardar bastante tiempo. Por ello, es recomendable comenzar por los puertos UDP más habituales y ampliar el análisis según los resultados obtenidos.

Para realizar un escaneo inicial más rápido, podemos utilizar:

sudo nmap -sU --top-ports 100 --open -T4 <IP>

Este comando escanea los 100 puertos UDP más habituales.

---

2. Descubrimiento de servicios y versiones

2.1. Nmap TCP

Comando:

sudo nmap -sCV -p- --open -T4 <IP>

Este comando realiza un escaneo de todos los puertos TCP de la máquina objetivo para identificar los servicios activos y sus versiones, ejecutando los scripts predeterminados de Nmap para obtener información adicional sobre los servicios detectados y mostrando los puertos abiertos o potencialmente abiertos.

El parámetro `-sC` ejecuta los scripts predeterminados de Nmap, mientras que `-sV` intenta identificar el software y la versión de los servicios encontrados.

También podemos especificar los puertos que queremos consultar mediante el parámetro `-p`, evitando escanear todos los puertos si ya conocemos cuáles están abiertos.

Ejemplo:

sudo nmap -sCV -p22,80,445 --open -T4 <IP>

Este comando realiza la detección de servicios, versiones y scripts predeterminados únicamente sobre los puertos TCP 22, 80 y 445.

2.2. Nmap UDP

Comando:

sudo nmap -sU -sV --open -T4 <IP>

Este comando realiza un escaneo de los puertos UDP más habituales de la máquina objetivo para identificar posibles servicios y detectar sus versiones cuando sea posible.

El parámetro `-sU` realiza el escaneo UDP, mientras que `-sV` intenta identificar los servicios que responden en los puertos detectados.

También podemos especificar los puertos que queremos consultar mediante el parámetro `-p`, evitando escanear todos los puertos UDP si ya conocemos cuáles nos interesa investigar.

Ejemplo:

sudo nmap -sU -sV -p53,123,161 --open -T4 <IP>

Este comando investiga los puertos UDP 53, 123 y 161, habitualmente asociados a DNS, NTP y SNMP, respectivamente.

Si queremos escanear todos los puertos UDP, podemos utilizar:

sudo nmap -sU -sV -p- --open -T4 <IP>

Este escaneo puede tardar bastante tiempo, por lo que es recomendable comenzar con los puertos más habituales y ampliar el análisis cuando sea necesario.

---

3. Interactuar con el servicio

3.1. Netcat TCP

Comando:

nc -nvvv -z <IP> <PUERTO>

Este comando intenta establecer una conexión TCP con un puerto concreto de la máquina objetivo para comprobar si acepta conexiones.

El parámetro `-n` evita la resolución DNS, `-vvv` aumenta el nivel de detalle de los mensajes y `-z` permite comprobar la conexión sin intercambiar datos de aplicación.

Es útil para verificar la conectividad con un puerto específico después de haberlo identificado mediante Nmap.

Ejemplo:

nc -nvvv -z 10.10.10.10 80

Este comando comprueba si es posible establecer una conexión TCP con el puerto 80 de la máquina objetivo.

3.2. Netcat UDP

Comando:

nc -nuvv -z <IP> <PUERTO>

Este comando realiza una comprobación UDP contra un puerto concreto de la máquina objetivo.

El parámetro `-u` indica que se utilizará UDP, mientras que `-n`, `-vv` y `-z` mantienen las funciones explicadas anteriormente.

A diferencia de TCP, UDP no establece una conexión. Por tanto, el resultado de Netcat no permite confirmar de forma fiable que el puerto esté abierto.

Para comprobar e investigar servicios UDP, es preferible utilizar Nmap y, cuando sea necesario, herramientas específicas del protocolo correspondiente.

Ejemplo:

nc -nuvv -z 10.10.10.10 161

Este comando intenta realizar una comprobación UDP contra el puerto 161, habitualmente asociado a SNMP.

4. Identificación e investigación de servicios

Una vez identificados los puertos abiertos y las versiones de los servicios mediante Nmap, consultaremos los resultados en Whatportis y HackTricks para obtener información adicional sobre los servicios detectados y conocer las técnicas de enumeración que podemos aplicar.

4.1. Whatportis

Página web: Whatportis

Utilizaremos esta página para consultar los puertos identificados durante el escaneo y conocer qué servicios suelen utilizar esos puertos. Esto nos ayudará a orientar la investigación inicial y a identificar qué protocolo podría estar asociado a cada puerto.

Debemos tener en cuenta que el número de puerto no confirma por sí solo qué servicio se está ejecutando. Por ello, contrastaremos la información con los resultados de detección de versiones de Nmap.

4.2. HackTricks

Página web: HackTricks

Una vez identificado el servicio, utilizaremos HackTricks para consultar técnicas de enumeración, comandos útiles, configuraciones habituales y posibles vectores de ataque relacionados con dicho servicio.

Por ejemplo, si encontramos los puertos 21 (FTP), 80 (HTTP) o 445 (SMB), buscaremos sus correspondientes apartados para determinar qué pruebas de enumeración podemos realizar y qué información adicional podemos obtener.